Requirements

DevSecOps CI/CD Pipeline

1. Runtime and repository requirements

- Python 3.10 or newer for the local auditor
- Windows, macOS, or Linux
- A local repository containing GitHub Actions workflow YAML files
- GitHub Actions enabled to run CI jobs

2. Python dependencies

No third-party Python packages are required. The local auditor uses Python's standard library. The **requirements.txt** file is intentionally minimal.

3. CI/CD security tools

Trivy: use the approved Trivy CLI or GitHub Action to scan source files, dependencies, container images, or infrastructure-as-code according to project scope. Configure severity thresholds and failure behavior.

SonarQube/SonarCloud: configure the project key, server/organization details, and authentication through approved GitHub repository secrets or variables. Configure quality-gate enforcement explicitly; a scan alone may not block a deployment.

4. Recommended GitHub configuration

- Set least-privilege workflow permissions.
- Do not commit tokens, passwords, or private keys.
- Review third-party actions and pin them to full commit SHAs where required.
- Treat pull-request code as untrusted and avoid exposing secrets to untrusted workflows.

5. Scope and limitations

The Python script statically inspects local workflow YAML text. It does not execute CI jobs, call GitHub APIs, run Trivy, connect to SonarQube, or prove the pipeline is secure. Validate the actual workflow in a controlled repository and review findings in context.